COMPTIA SECURITY+ SY0-701 | DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.8 · Incident Planning

Mestre CyberSec · **Aula 4.8 — Incident Planning** (6:50) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Tabletop exercise (jogo fictício — treina decisores); simulation (falta simulada); RCA (root cause analysis — o porquê real); documentation; playbook por tipo (ransomware/phishing).

💡 Highlights que a prova CompTIA cobra

- Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real
- RCA: a causa RAIZ (o porquê), não o sintoma

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'simulated exercise without real impact'=tabletop

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.8 — Incident Planning)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Exercício de Mesa (Tabletop)

Exercício de discussão em que a equipe de resposta percorre um cenário hipotético de incidente em uma sala de reunião (o 'jogo de mesa'), avaliando planos, papéis e decisões sem tocar em sistemas reais ou causar impacto algum.

⚠ ***Armadilha CompTIA:*** *Gatilho clássico: 'simulated exercise WITHOUT real impact', 'discussion-based', 'walkthrough'. Não confunda com Simulation — a prova troca propositalmente os dois termos nas opções de resposta.*

• Simulação (Exercício de Simulação)

Exercício funcional que executa uma falha ou ataque simulado no ambiente real (ex.: failover para o site de backup), validando os procedimentos em condições próximas do real.

⚠ ***Armadilha CompTIA:*** *Fórmula da prova: Simulation = ambiente REAL + incidente SIMULADO. Se citar 'real environment' ou 'failover test', é simulation; se for 'sem impacto real, apenas discussão', é tabletop.*

• Análise de Causa Raiz (RCA)

Processo de identificar a causa fundamental e real do incidente (ex.: ausência de patch), e não apenas tratar os sintomas visíveis (ex.: o próprio malware).

⚠ ***Armadilha CompTIA:*** *'A causa RAIZ — o porquê real' = root cause. O sintoma vai no incident report; a RCA responde o porquê profundo do incidente ter ocorrido. Caiu por phishing? A causa raiz pode ser falta de treinamento ou MFA, não o e-mail em si.*

• Playbook (Manual de Resposta por Tipo de Incidente)

Guia documentado e passo a passo criado para responder a um tipo específico de incidente (ransomware, phishing, DNS, injeção de SQL, DoS), garantindo ações consistentes e suportando automação via SOAR.

⚠ ***Armadilha CompTIA:*** *Playbook = por TIPO de incidente (ransomware/phishing). Runbook = por tarefa/rotina técnica. A prova adora inverter esses dois — leia com atenção qual dos dois a questão pede.*

• Runbook (Manual de Execução de Tarefas)

Conjunto detalhado, repetível e geralmente automatizável de instruções para executar uma operação de rotina ou tarefa técnica específica (ex.: restaurar um banco de dados, rotacionar chaves).

⚠ ***Armadilha CompTIA:*** *Gatilho: 'step-by-step checklist for a specific task/operation' = runbook. Distinção-chave: runbook executa uma tarefa; playbook reage a um cenário de incidente.*

• **Plano de Resposta a Incidentes**
Plano documentado que define objetivos, escopo, papéis e responsabilidades, plano de comunicação, tipos/categorias de incidente, niveles de severidade e caminhos de escalada.

⚠️ ***Armadilha CompTIA:*** *Palavras-chave da prova: 'roles', 'communication plan', 'severity', 'escalation paths'. Se a questão perguntar 'quem faz o quê, quando e como comunicar' antes do incidente ocorrer, a resposta é o IR plan.*

• **Documentação (Registro de Incidente / Relatório de Incidente)**
Registro estruturado dos incidentes — logs, linha do tempo, evidências e relatórios escritos — necessário para forense, conformidade legal/regulatória e alimentação das lições aprendidas.

⚠️ ***Armadilha CompTIA:*** *'If it isn't documented, it didn't happen' — a prova enfatiza documentar TUDO: suporta chain of custody, compliance e a melhoria contínua do processo de resposta. Documentação incompleta = opção errada.*

• **Teste de Failover (Transição para Backup)**
Exercício simulado que transfere intencionalmente serviços para sistemas redundantes/backup (site secundário, cluster HA) para validar a continuidade de negócios sem um desastre real.

⚠️ ***Armadilha CompTIA:*** *É o exemplo canônico de SIMULATION na prova: ambiente real, falha simulada. Se o cenário migrar serviços para o site de backup propositadamente, a resposta não é tabletop — é simulation/failover test.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

A equipe executiva de uma empresa de serviços financeiros quer praticar como tomaria decisões e se comunicaria com reguladores e clientes durante uma crise de ransomware. Nenhum sistema de produção será tocado, e o objetivo é discutir papéis, caminhos de escalonamento e considerações legais. Qual atividade se encaixa melhor nesse objetivo?

A) Exercício de mesa (tabletop)

B) Teste de failover em escala real

C) Teste de penetração

D) Análise de causa raiz

QUESTÃO 2 · CENÁRIO DE EXAME

Após um exercício baseado em discussão, um gerente do SOC quer que a equipe de resposta a incidentes pratique ações de contenção e erradicação contra um surto de malware simulado em uma réplica isolada da rede de produção. O exercício não deve afetar serviços ativos, mas deve exigir ferramentas e procedimentos práticos. Qual atividade deve ser usada?

A) Exercício de mesa (tabletop)

B) Simulação

C) Análise de causa raiz

D) Revisão de relatório de incidente

QUESTÃO 3 · CENÁRIO DE EXAME

Uma empresa se recuperou de um incidente de phishing que levou a acesso não autorizado à caixa de correio. A liderança quer entender a falha de controle subjacente que permitiu o comprometimento e identificar ações corretivas para evitar recorrência. Qual atividade deve ser realizada?

A) Teste de failover

B) Exercício de mesa (tabletop)

C) Análise de causa raiz

D) Validação de playbook

QUESTÃO 4 · CENÁRIO DE EXAME

Uma organização de saúde quer um conjunto predefinido de etapas de resposta específicas para incidentes que oriente a equipe quanto a contenção, isolamento, considerações de pagamento, notificação regulatória e coordenação de recuperação em um ataque de extorsão que criptografa dados. Qual artefato deve ser criado?

A) Runbook para restauração de backup de banco de dados

B) Plano de resposta a incidentes

C) Registro de incidentes

D) Playbook de ransomware

QUESTÃO 5 · CENÁRIO DE EXAME

Durante um incidente declarado, um administrador de backup deve restaurar um banco de dados crítico a partir de backups imutáveis seguindo comandos exatos, verificações de validação e dependências em uma ordem específica. Qual documento o administrador deve usar?

A) Runbook

B) Playbook

C) Plano de resposta a incidentes

D) Relatório de exercício de mesa

QUESTÃO 6 · CENÁRIO DE EXAME

Durante a resposta a uma intrusão de rede, a equipe jurídica solicita um registro cronológico de todas as ações dos respondedores, horários, evidências manuseadas e decisões importantes tomadas durante a investigação em andamento. Qual documento os respondedores de incidentes devem manter?

A) Relatório de incidente

B) Registro de incidentes

C) Análise de causa raiz

D) Plano de teste de failover

QUESTÃO 7 · CENÁRIO DE EXAME

Após encerrar uma investigação de violação de dados, o CISO precisa de um documento formal que resuma o escopo do incidente, o impacto nos negócios, a causa raiz, as evidências, as lições aprendidas e o status das ações corretivas para executivos e auditores. Qual documento deve ser produzido?

A) Registro de incidentes

B) Runbook

C) Relatório de incidente

D) Playbook de phishing

QUESTÃO 8 · CENÁRIO DE EXAME

A equipe de recuperação de desastres de uma organização quer verificar se seu data center alternativo pode assumir as operações de sistemas críticos quando o site primário ficar indisponível devido a um incidente. A equipe planeja alternar as operações e depois voltar. Qual atividade está sendo realizada?

A) Exercício de mesa (tabletop)

B) Simulação

C) An��lise de causa raiz

D) Teste de failover

QUESTÃO 9 · CENÁRIO DE EXAME

Um diretor de segurança recém-contratado deve documentar a abordagem geral da organização para preparar, detectar, analisar, conter, erradicar, recuperar e aprender com incidentes de segurança. O documento deve definir papéis, critérios de ativação, caminhos de comunicação e coordenação entre departamentos. Qual documento é necessário?

A) Plano de resposta a incidentes

B) Playbook de ransomware

C) Runbook

D) Registro de incidentes

QUESTÃO 10 · CENÁRIO DE EXAME

O SOC quer um guia padronizado e específico para o tipo de incidente no tratamento de mensagens de e-mail suspeitas reportadas, incluindo triagem, análise de cabeçalhos, entrevista com usuário, busca na caixa de correio, contenção e comunicação ao usuário. Qual artefato atende melhor a essa necessidade?

A) Plano de resposta a incidentes

B) Playbook de phishing

C) Relatório de incidente

D) Teste de failover

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Exercício de mesa (tabletop)

O exercício de mesa é uma sessão baseada em discussão que reúne tomadores de decisão para percorrer um incidente hipotético. Ele valida papéis, comunicação, escalonamento e coordenação sem afetar sistemas ativos. Teste de failover valida continuidade técnica, teste de penetração avalia vulnerabilidades exploráveis, e RCA é feito após um incidente para identificar a causa real.

Questão 2: Alternativa B — Simulação

A simulação fornece um ambiente prático e realista no qual os respondedores executam ações técnicas contra um incidente simulado sem impactar a produção. O exercício de mesa é baseado em discussão, a RCA é uma investigação pós-incidente, e revisar um relatório de incidente não oferece prática de resposta.

Questão 3: Alternativa C — Análise de causa raiz

A análise de causa raiz examina o incidente para determinar por que ele ocorreu, incluindo controles falhos ou ausentes, e identifica ações corretivas. Um teste de failover verifica continuidade, um exercício de mesa pratica tomada de decisão, e a validação de playbook verifica etapas de resposta, mas não descobre por si só a causa subjacente.

Questão 4: Alternativa D — Playbook de ransomware

O playbook de ransomware é um guia específico por tipo de incidente que contém etapas predefinidas de resposta, pontos de decisão e requisitos de coordenação para ransomware. O plano de resposta a incidentes é a estrutura geral, um runbook é um procedimento técnico detalhado, e um registro de incidentes é um histórico cronológico.

Questão 5: Alternativa A — Runbook

Um runbook contém procedimentos técnicos detalhados, passo a passo, para uma tarefa operacional específica, como restaurar um banco de dados na sequência correta. Um playbook fornece orientação de resposta de alto nível por tipo de incidente, o plano de resposta a incidentes define o programa geral, e um relatório de exercício de mesa registra observações do exercício.

Questão 6: Alternativa B — Registro de incidentes

O registro de incidentes é mantido durante o incidente como um registro cronológico contemporâneo de ações, horários, evidências e decisões. O relatório de incidente é um resumo formal pós-incidente, a RCA explica a causa após a investigação, e um plano de teste de failover documenta testes de continuidade.

Questão 7: Alternativa C — Relatório de incidente

O relatório de incidente é o documento formal pós-incidente que resume escopo, impacto, causa raiz, lições aprendidas e ações corretivas para a gestão e auditores. O registro de incidentes é um registro cronológico bruto, um runbook é um procedimento técnico, e um playbook orienta atividades de resposta.

Questão 8: Alternativa D — Teste de failover

Um teste de failover valida que sistemas redundantes ou um site alternativo podem assumir as operações quando o recurso primário falha, e normalmente inclui a volta. Um exercício de mesa é baseado em discussão, uma simulação pratica resposta a incidentes em ambiente replicado, e a RCA investiga um incidente após ele ocorrer.

Questão 9: Alternativa A — Plano de resposta a incidentes

O plano de resposta a incidentes é o documento geral que define o programa de resposta a incidentes, fases, papéis, critérios de ativação, comunicação e coordenação. Um playbook é específico por tipo de incidente, um runbook contém procedimentos técnicos detalhados, e um registro de incidentes registra eventos durante um incidente.

Questão 10: Alternativa B — Playbook de phishing

O playbook de phishing é um guia específico por tipo de incidente que padroniza as etapas para tratar mensagens de phishing reportadas, da triagem à contenção e comunicação. O plano de resposta a incidentes é a estrutura geral, um relatório de incidente é um resumo pós-incidente, e um teste de failover valida a continuidade.